

Integrazione Sicura LLM e Server MCP

Demo Finale - Architettura Runtime e Privacy by Design

Ettore Miglioranza

Saidea/Miorelli

Aprile 2026

Obiettivi della Demo Finale

La demo valida il flusso operativo completo con anonimizzazione reversibile.

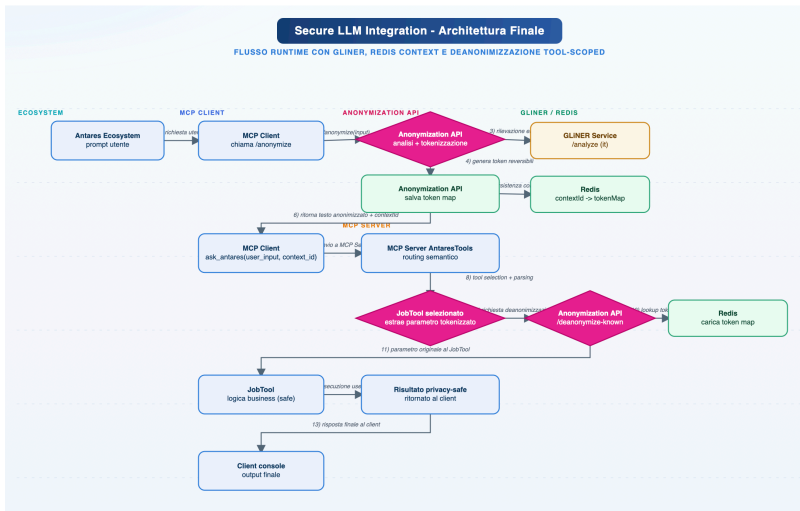
- ▶ Il prompt viene anonimizzato prima di attraversare il confine MCP.
- ▶ Il modello LLM viene usato solo per routing semantico e selezione tool.
- ▶ I parametri sensibili vengono deanonimizzati solo nel punto di esecuzione tool.
- ▶ L'esito restituito al client rimane controllato e privacy-safe.

Architettura Runtime Validata

Componenti attivi nella demo:

- ▶ **MCP Client:** invoca `/anonymize`, poi `ask_antares(user_input, context_id)`.
- ▶ **Anonymization API:** analisi entita, tokenizzazione e endpoint `/deanonymize-known`.
- ▶ **GLiNER Service:** estrazione entita multilingua.
- ▶ **Redis Context Store:** persistenza `contextId` -> `tokenMap`.
- ▶ **MCP Server / JobTools:** esecuzione deterministica dei casi d'uso.

Grafico Finale - Runtime Flow



Evidenze e Insight Operativi

Risultati osservati durante l'esecuzione:

- ▶ Il `contextId` viene emesso e tracciato lungo tutto il ciclo.
- ▶ I token anonimizzati attraversano il layer LLM senza esposizione dati reali.
- ▶ La deanonimizzazione avviene in scope controllato, lato server tool.
- ▶ In caso di errore di deanonimizzazione, il flusso rimane resiliente.

Formule di Calcolo Costi LLM e Parametri

Formule usate nel modello di stima:

$$\text{TokenIn}_{mese} = R \cdot T_{in}$$

$$\text{TokenOut}_{mese} = R \cdot T_{out}$$

$$\text{Costo}_{mese} = \frac{\text{TokenIn}_{mese}}{10^6} \cdot P_{in} + \frac{\text{TokenOut}_{mese}}{10^6} \cdot P_{out}$$

$$\text{Costo}_{anno} = 12 \cdot \text{Costo}_{mese}$$

Parametri nel dettaglio:

- ▶ R : richieste utente/mese che arrivano a ask_antares.
- ▶ T_{in} : token medi input/chiamata (system prompt + user prompt + schema tool).
- ▶ T_{out} : token medi output/chiamata (risposta modello + eventuale testo post-tool).
- ▶ P_{in}, P_{out} : prezzo provider in USD per 1 milione di token input/output.

Ipotesi di Carico e Modello Token

Ipotesi derivate dal codebase attuale (tool routing + function invocation):

- ▶ 1 chiamata LLM esterna per richiesta utente (tool ask_antares).
- ▶ Token medi per chiamata: **input = 2000, output = 180.**
- ▶ Prezzi indicativi provider esterno: **3 USD/MTok input, 15 USD/MTok output.**
- ▶ Due viste di stima: **cost scalability** (alto volume) e **real operativo** (basso volume).

Questa separazione mostra sia il comportamento a scala enterprise sia l'impatto realistico nella fase attuale.

Real Operativo - Stima Costi (1000 chiamate/mese = Alto)

Scenario	Req/mese	Token in/out mese	Costo mese (USD)	Costo anno (USD)
Basso	300	0.6M / 0.054M	2.61	31.32
Medio	700	1.4M / 0.126M	6.09	73.08
Alto	1,000	2.0M / 0.18M	8.70	104.40

- ▶ In questa vista, **1000 richieste/mese** rappresenta già il limite alto del contesto operativo attuale.
- ▶ Costo LLM variabile contenuto: utile per mantenere un fallback esterno anche con on-prem primario.
- ▶ Costi non inclusi: infrastruttura locale, osservabilità, manutenzione modello e MLOps.

Cost Scalability - Stima Costi Esterni LLM (Mese/Anno)

Scenario	Req/mese	Token in/out mese	Costo mese (USD)	Costo anno (USD)
Basso	10,000	20.0M / 1.8M	87	1,044
Base	50,000	100.0M / 9.0M	435	5,220
Alto	200,000	400.0M / 36.0M	1,740	20,880

- ▶ Driver principale costo: token input (prompt di sistema + schema tool + user prompt).
- ▶ Ottimizzazione prioritaria: riduzione prompt/router e schema tools inoltrato al modello.
- ▶ Questa vista serve per validare la sostenibilita economica al crescere del traffico.

Complessita del Task Assegnato al Router LLM

Complessita osservata nel codice corrente:

- ▶ **Intent classification:** scelta 1 tool tra un insieme ristretto (UC A/B/C + lookup).
- ▶ **Slot extraction:** estrazione di 1 parametro principale (personName o cantiereName) + context_id.
- ▶ **Policy constraints:** una sola chiamata tool, privacy instructions forti, output controllato.
- ▶ **Niente reasoning profondo:** la logica business e computazionale sta nei tool C#.

Valutazione sintetica: **complessita bassa-media**, alta sensibilita su affidabilita e compliance.

LLM On-Prem: Configurazione Scelta e Costi Reali

Fattibile per il compito attuale di routing.

- ▶ **Configurazione scelta:** GPU 12 GB (meglio 16 GB), Llama 3.1 8B in 4-bit, RAM 32 GB.
- ▶ **Uso target:** basso traffico, ideale per PoC e routing MCP con prompt brevi.
- ▶ **Costo una tantum (macchina completa):** circa **1,100–1,700 EUR**.

Energia mensile stimata (solo inferenza, macchina non H24):

Richieste/mese	Costo energia mese (EUR)	Costo energia anno (EUR)
100	0.01–0.07	0.12–0.84
500	0.06–0.34	0.72–4.08
1,000	0.12–0.67	1.44–8.04

- ▶ Se la macchina resta accesa H24, il costo reale é dominato dall'idle: **circa 8–18 EUR/mese**.
- ▶ Costi extra da considerare: monitoring, backup, aggiornamenti modello e presidio operativo.

Piano di Sviluppo — Timeline Stimata (6–7 Settimane)

Settimana	Scope
1	Spec OpenAPI + generazione client NSwag
2	Sostituzione stub + wiring 6 tool esistenti
3	OAuth aziendale — token flow, refresh, propagazione identità al boundary MCP
4	RBAC — mappatura ruoli → accesso tool, enforcement server-side, audit log
5	EmailTool + ReportTool — nuovi MCP tool (invio mail, generazione PDF/Excel)
6	Integration test su tutti gli UC + hardening errori/retry/Redis TTL
Buffer	UAT con utenti reali, staging, sign-off

- ▶ La sostituzione del backend Miorelli è **mirata**: dal fall back sui mock alle API del db anonimizzato.
- ▶ OAuth e RBAC richiedono **design cross-boundary**: impatto su client, server e identity provider.

Conclusioni della Presentazione

- ▶ Architettura pronta per demo enterprise con separazione netta delle responsabilità.
- ▶ Sicurezza applicata per design: nessun dato sensibile in chiaro al router LLM.
- ▶ Struttura estendibile a nuovi tool MCP e nuovi use case operativi.
- ▶ Con routing a bassa-media complessità, un modello on-prem light e una scelta realistica.